

Cybersecurity Daily Newsletter

Vol. 002 | 2026-06-16 07:00 WIB

Top 5 Highlights

- SimpleHelp bug lets hackers create rogue remote support accounts
- Copilot 'SearchLeak' Attack Allows 1-Click Data Theft
- Cisco fixes SD-WAN vManage flaw exploited in zero-day attacks
- China-Nexus Actor Spy on US Researchers Undetected for a Year
- Council of Europe investigates ShinyHunters data breach claims

Threat Intelligence (10)

01. China-Nexus Actor Spy on US Researchers Undetected for a Year

Google discovered and disrupted the sprawling campaign, which stole RedCAP credentials to target numerous institutions and exfiltrate sensitive data.

Why it matters: Threat-actor tradecraft and active campaigns help defenders anticipate techniques likely to be used against their environment.

Recommendation: Update detections and threat hunts using reported TTPs/IOCs, review email/web controls, and harden high-risk internet-facing services.

Sources: <https://www.darkreading.com/threat-intelligence/china-nexus-actor-us-researchers-undetected>

02. Chinese hackers breach REDCap servers, steal medical research

A China-linked espionage campaign targeted exposed REDCap servers to deploy the InfiniteRed malware and steal sensitive data from a medical institution in North America. [...]

Why it matters: Threat-actor tradecraft and active campaigns help defenders anticipate techniques likely to be used against their environment.

Recommendation: Update detections and threat hunts using reported TTPs/IOCs, review email/web controls, and harden high-risk internet-facing services.

Sources: <https://www.bleepingcomputer.com/news/security/chinese-hackers-breach-redcap-servers-steal-medical-research/>

03. Webinar: How behavioral AI stops phishing and account takeovers

Modern phishing, BEC, and account takeover attacks increasingly bypass traditional email defenses and create operational strain for security teams. This webinar explores how behavioral AI can help automate detection, investigation, and remediation to reduce alert fatigue and accelerate response times. [...]

Why it matters: Threat-actor tradecraft and active campaigns help defenders anticipate techniques likely to be used against their environment.

Recommendation: Tighten email authentication and filtering, run targeted user awareness, and monitor for lookalike domains and suspicious inbox rules.

Sources: <https://www.bleepingcomputer.com/news/security/webinar-how-behavioral-ai-stops-phishing-and-account-takeovers/>

04. [+24h Old] FBI disrupts massive AI-powered phishing service using a million URLs

In a coordinated effort, the FBI, working with Google and Black Lotus Labs, has dismantled a massive Chinese phishing-as-a-service operation called Outsider Enterprise with thousands of phishing websites used to steal credit card data and passwords. [...]

Why it matters: Threat-actor tradecraft and active campaigns help defenders anticipate techniques likely to be used against their environment.

Recommendation: Tighten email authentication and filtering, run targeted user awareness, and monitor for lookalike domains and suspicious inbox rules.

Sources: <https://www.bleepingcomputer.com/news/security/fbi-disrupts-massive-ai-powered-phishing-service-using-a-million-urls/>

05. [+48h Old] NPM 12 Will Change Script Execution Behavior to Prevent Supply Chain Attacks

By default, npm install will no longer execute scripts from dependencies, unless explicitly allowed. The post NPM 12 Will Change Script Execution Behavior to Prevent Supply Chain Attacks appeared first on SecurityWeek .

Why it matters: Threat-actor tradecraft and active campaigns help defenders anticipate techniques likely to be used against their environment.

Recommendation: Audit build pipelines, rotate CI/CD secrets, enforce package integrity controls, and review developer workstation hardening.

Sources: <https://www.securityweek.com/npm-12-will-change-script-execution-behavior-to-prevent-supply-chain-attacks/>

06. [+48h Old] China-nexus group hid in Linux login system for nearly a decade

The group's operation, dubbed Operation Highland, involved backdooring the Pluggable Authentication Modules (PAM) and OpenSSH components, which are fundamental to user authentication on Linux systems.

Why it matters: Threat-actor tradecraft and active campaigns help defenders anticipate techniques likely to be used against their environment.

Recommendation: Update detections and threat hunts using reported TTPs/IOCs, review email/web controls, and harden high-risk internet-facing services.

Sources: <https://www.scworld.com/brief/china-nexus-group-hid-in-linux-login-system-for-nearly-a-decade>

07. [+48h Old] Over 400 Arch Linux AUR Packages Hijacked to Deploy Infostealer and eBPF Rootkit

Attackers took over more than 400 packages in the Arch User Repository (AUR) this week and rewrote their build scripts to install a credential stealer on any machine that built them. The malware is a Rust binary built to harvest developer secrets. When it lands with root, it can also load an eBPF rootkit to hide itself. The AUR is Arch Linux's community pac...

Why it matters: Threat-actor tradecraft and active campaigns help defenders anticipate techniques likely to be used against their environment.

Recommendation: Update detections and threat hunts using reported TTPs/IOCs, review email/web controls, and harden high-risk internet-facing services.

Sources: <https://thehackernews.com/2026/06/over-400-arch-linux-aur-packages.html>

08. [+48h Old] China-Linked Hackers Backdoored Linux Login Software to Hide for Nearly a Decade

Instead of hiding on the laptops and servers defenders watch most closely, a China-nexus group spent close to a decade hidden inside the Linux login system itself. Sygnia, which tracks the group as Velvet Ant, says it backdoored the PAM and OpenSSH components that decide who is allowed to sign in, planting its access where ordinary cleanup could not

reach i...

Why it matters: Threat-actor tradecraft and active campaigns help defenders anticipate techniques likely to be used against their environment.

Recommendation: Update detections and threat hunts using reported TTPs/IOCs, review email/web controls, and harden high-risk internet-facing services.

Sources: <https://thehackernews.com/2026/06/china-linked-hackers-backdoored-linux.html>

09. [+48h Old] Over 400 Arch Linux packages compromised to push rootkit, infostealer

More than 400 packages in the Arch User Repository (AUR) are distributing a Linux rootkit and infostealer malware targeting credentials and access tokens. [...]

Why it matters: Threat-actor tradecraft and active campaigns help defenders anticipate techniques likely to be used against their environment.

Recommendation: Update detections and threat hunts using reported TTPs/IOCs, review email/web controls, and harden high-risk internet-facing services.

Sources: <https://www.bleepingcomputer.com/news/security/over-400-arch-linux-packages-compromised-to-push-rootkit-infostealer/>

10. [+48h Old] Warrantless wiretaps cut off for a week following US Congress vote

Lawmakers have failed to extend a surveillance law that allows US intelligence agencies to monitor targets abroad without a warrant. Congress rejected a vote to extend Section 702 of the Foreign Intelligence Surveillance Act to July 2, which means, for a few days at least, some surveillance will be put on hold, for the first time since the Act was passed in...

Why it matters: Threat-actor tradecraft and active campaigns help defenders anticipate techniques likely to be used against their environment.

Recommendation: Update detections and threat hunts using reported TTPs/IOCs, review email/web controls, and harden high-risk internet-facing services.

Sources: <https://www.csoonline.com/article/4184603/warrantless-wiretaps-cut-off-for-a-week-following-u-s-congress-vote.html>

Latest Vulnerabilities (10)

01. SimpleHelp bug lets hackers create rogue remote support accounts

A vulnerability in the SimpleHelp remote management software allows unauthenticated attackers to create privileged technician accounts on servers using the OpenID Connect (OIDC) authentication protocol. [...]

Why it matters: Exploit-ready vulnerabilities can rapidly translate into compromise-especially for internet-facing services and widely deployed products.

Recommendation: Prioritize patching/mitigations, review exposure, and add detection for exploitation attempts (e.g., WAF/EDR signatures and logs).

Sources: <https://www.bleepingcomputer.com/news/security/simplehelp-bug-lets-hackers-create-rogue-remote-support-accounts/>

02. Copilot 'SearchLeak' Attack Allows 1-Click Data Theft

The critical, three-stage attack is now patched, but it's part of a new group of AI prompt-injection issues that use hidden URLs and other variables.

Why it matters: Exploit-ready vulnerabilities can rapidly translate into compromise-especially for internet-facing services and widely deployed products.

Recommendation: Prioritize patching/mitigations, review exposure, and add detection for exploitation attempts (e.g., WAF/EDR signatures and logs).

Sources: <https://www.darkreading.com/application-security/copilot-searchleak-attack-1-click-data-theft>

03. Cisco fixes SD-WAN vManage flaw exploited in zero-day attacks

Cisco has released security updates to address a vulnerability in the Catalyst SD-WAN Manager, tracked as CVE-2026-20262, that was exploited in attacks to escalate to root privileges. [...]

Why it matters: Exploit-ready vulnerabilities can rapidly translate into compromise-especially for internet-facing services and widely deployed products.

Recommendation: Prioritize patching/mitigations, review exposure, and add detection for exploitation attempts (e.g., WAF/EDR signatures and logs).

Sources: <https://www.bleepingcomputer.com/news/security/cisco-fixes-sd-wan-vmanage-flaw-exploited-in-zero-day-attacks/>

04. New attack turned Microsoft 365 Copilot into 1-click data theft tool

A critical vulnerability chain dubbed SearchLeak in Microsoft 365 Copilot Enterprise could allow attackers to steal sensitive data from a target's mailbox, OneDrive, or SharePoint account through a specially crafted URL. [...]

Why it matters: Exploit-ready vulnerabilities can rapidly translate into compromise-especially for internet-facing services and widely deployed products.

Recommendation: Prioritize patching/mitigations, review exposure, and add detection for exploitation attempts (e.g., WAF/EDR signatures and logs).

Sources: <https://www.bleepingcomputer.com/news/security/new-attack-turned-microsoft-365-copilot-into-1-click-data-theft-tool/>

05. Langflow RCE under active attack months after a patch was shipped

Enterprises using the open-source AI orchestration platform Langflow are being urged to patch a high-severity path traversal flaw amid active exploitation, despite a fix having been available for more than two months. The bug, which stems from improper handling of filenames in Langflow's file upload functionality, can allow attackers to write files to arbit...

Why it matters: Exploit-ready vulnerabilities can rapidly translate into compromise-especially for internet-facing services and widely deployed products.

Recommendation: Prioritize patching/mitigations, review exposure, and add detection for exploitation attempts (e.g., WAF/EDR signatures and logs).

Sources: <https://www.csoonline.com/article/4185063/langflow-rce-under-active-attack-months-after-a-patch-was-shipped.html>

06. Attackers can turn AI agent guardrails into denial-of-service weapons

Attackers can turn AI agent guardrails into denial-of-service weapons, according to new research that found a single poisoned document can dramatically slow shared AI agent workflows by trapping reasoning-based safety systems in extended thinking loops.

“Reasoning-based guardrails introduce a new attack surface where security mechanisms themselves become th...

Why it matters: Exploit-ready vulnerabilities can rapidly translate into compromise-especially for internet-facing services and widely deployed products.

Recommendation: Prioritize patching/mitigations, review exposure, and add detection for exploitation attempts (e.g., WAF/EDR signatures and logs).

Sources: <https://www.csoonline.com/article/4185051/attackers-can-turn-ai-agent-guardrails-into-denial-of-service-weapons.html>

07. Sovereign cloud won't fix your AI risk. Identity governance will

Your board is asking. Your legal team is asking. Your auditors will be asking: Should AI workloads move to sovereign cloud, or stay on AWS, Azure or GCP? European enterprises have already run this experiment - under real regulatory pressure, with real money and real consequences. Many discovered that sovereign cloud alone didn't deliver the control they exp...

Why it matters: Exploit-ready vulnerabilities can rapidly translate into compromise-especially for internet-facing services and widely deployed products.

Recommendation: Prioritize patching/mitigations, review exposure, and add detection for exploitation attempts (e.g., WAF/EDR signatures and logs).

Sources: <https://www.csoonline.com/article/4184634/sovereign-cloud-wont-fix-your-ai-risk-identity-governance-will.html>

08. [+24h Old] CVE-2026-54411 | Linux-PAM up to 1.7.2 pam_userdb.c strncmp timing discrepancy (EUVD-2026-36662)

A vulnerability identified as problematic has been detected in Linux-PAM up to 1.7.2 . This issue affects the function strncmp of the file modules/pam_userdb/pam_userdb.c . Performing a manipulation results in observable timing discrepancy. This vulnerability is cataloged as CVE-2026-54411...

Why it matters: Exploit-ready vulnerabilities can rapidly translate into compromise-especially for internet-facing services and widely deployed products.

Recommendation: Prioritize patching/mitigations, review exposure, and add detection for exploitation attempts (e.g., WAF/EDR signatures and logs).

Sources: <https://vuldb.com/vuln/370870>

09. [+24h Old] CVE-2026-54413 | driftregion iso14229 up to 0.9.0 iso14229.c Handle_0x27_SecurityAccess integer underflow (EUVD-2026-36664)

A vulnerability categorized as critical has been discovered in driftregion iso14229 up to 0.9.0 . This vulnerability affects the function Handle_0x27_SecurityAccess of the file

iso14229.c . Such manipulation leads to integer underflow. This vulnerability is listed as CVE-2026-54413 . The attack may be performed from remote. There is no available exploit.

Why it matters: Exploit-ready vulnerabilities can rapidly translate into compromise-especially for internet-facing services and widely deployed products.

Recommendation: Prioritize patching/mitigations, review exposure, and add detection for exploitation attempts (e.g., WAF/EDR signatures and logs).

Sources: <https://vuldb.com/vuln/370869>

10. [+24h Old] CVE-2026-54410 | debevv nanoMODBUS up to 1.23.0 MBAP recv_msg_header off-by-one (EUVD-2026-36661)

A vulnerability was found in debevv nanoMODBUS up to 1.23.0 . It has been rated as critical . This affects the function recv_msg_header of the component MBAP Handler . This manipulation causes off-by-one. This vulnerability is tracked as CVE-2026-54410 . The attack is possible to be carried out remotely. No exploit exists.

Why it matters: Exploit-ready vulnerabilities can rapidly translate into compromise-especially for internet-facing services and widely deployed products.

Recommendation: Prioritize patching/mitigations, review exposure, and add detection for exploitation attempts (e.g., WAF/EDR signatures and logs).

Sources: <https://vuldb.com/vuln/370868>

Data Breach & Cybercrime (10)

01. Council of Europe investigates ShinyHunters data breach claims

The Council of Europe, the continent's oldest intergovernmental body, is probing claims of a data breach made by the ShinyHunters extortion group over the weekend. [...]

Why it matters: Breaches and cybercrime activity signal where attackers are focusing and what data types are actively monetized.

Recommendation: Validate incident-response readiness, monitor for exposed credentials, and reinforce MFA, phishing resistance, and data-loss controls.

Sources: <https://www.bleepingcomputer.com/news/security/council-of-europe-investigates-shinyhunters-data-breach-claims/>

02. FBI: Fraudsters use couriers to steal money in crypto scams

The U.S. Federal Bureau of Investigation (FBI) warned that criminals are using couriers to collect money from victims of cryptocurrency investment scams, also known as pig butchering or romance baiting. [...]

Why it matters: Breaches and cybercrime activity signal where attackers are focusing and what data types are actively monetized.

Recommendation: Validate incident-response readiness, monitor for exposed credentials, and reinforce MFA, phishing resistance, and data-loss controls.

Sources: <https://www.bleepingcomputer.com/news/security/fbi-fraudsters-use-couriers-to-steal-money-in-crypto-scams/>

03. 15th June - Threat Intelligence Report

For the latest discoveries in cyber research for the week of 15th June, please download our Threat Intelligence Bulletin. TOP ATTACKS AND BREACHES The University of Nottingham, a UK research university, has suffered a data breach after ShinyHunters accessed its student records system. The incident affected about 454,600 current and former students and expos...

Why it matters: Breaches and cybercrime activity signal where attackers are focusing and what data types are actively monetized.

Recommendation: Validate incident-response readiness, monitor for exposed credentials, and reinforce MFA, phishing resistance, and data-loss controls.

Sources: <https://research.checkpoint.com/2026/15th-june-threat-intelligence-report/>

04. Infinite Campus data breach affects 137,000 school staff accounts

The ShinyHunters extortion gang stole personal information from more than 137,000 school staff accounts in a Salesforce data theft attack that targeted the widely used Infinite Campus K-12 student information system in March. [...]

Why it matters: Breaches and cybercrime activity signal where attackers are focusing and what data types are actively monetized.

Recommendation: Validate incident-response readiness, monitor for exposed credentials, and reinforce MFA, phishing resistance, and data-loss controls.

Sources: <https://www.bleepingcomputer.com/news/security/infinite-campus-data-breach-affects-137-000-school-staff-accounts/>

05. Governing the ghost workforce

Every enterprise security team is fighting a workforce problem they cannot see on any org chart. Bots, service accounts, API keys, OAuth tokens, machine certificates - non-human identities now outnumber human ones in most large organisations, often by a factor of ten to one. They authenticate constantly, operate across every environment, and when forgotten,...

Why it matters: Breaches and cybercrime activity signal where attackers are focusing and what data types are actively monetized.

Recommendation: Validate incident-response readiness, monitor for exposed credentials, and reinforce MFA, phishing resistance, and data-loss controls.

Sources: <https://www.csoononline.com/article/4184637/governing-the-ghost-workforce.html>

06. 5 runtime signals for catching a compromised AI agent

In June 2025, Simon Willison, the engineer who coined the term "prompt injection," published a warning that circulated widely through the security community. He called it the lethal trifecta - three capabilities that, when combined in a single AI agent, create a near-guaranteed path to exploitation through indirect prompt injection: access to private data;...

Why it matters: Breaches and cybercrime activity signal where attackers are focusing and what data types are actively monetized.

Recommendation: Validate incident-response readiness, monitor for exposed credentials, and reinforce MFA, phishing resistance, and data-loss controls.

Sources:

<https://www.csoonline.com/article/4184681/5-runtime-signals-for-catching-a-compromised-ai-agent.html>

07. [+48h Old] Novo Nordisk discloses data breach affecting patient and healthcare professional information

Attackers gained access to Novo Nordisk's internal IT systems, copying non-public data without authorization.

Why it matters: Breaches and cybercrime activity signal where attackers are focusing and what data types are actively monetized.

Recommendation: Validate incident-response readiness, monitor for exposed credentials, and reinforce MFA, phishing resistance, and data-loss controls.

Sources: <https://www.scworld.com/brief/novo-nordisk-discloses-data-breach-affecting-patient-and-health-care-professional-information>

08. [+48h Old] Maine disables data breach notification portal after fake disclosures

Maine has taken its public data breach reporting portal offline after fraudulent breach disclosures were published on the state's website, prompting a review of procedures to prevent abuse in the future. [...]

Why it matters: Breaches and cybercrime activity signal where attackers are focusing and what data types are actively monetized.

Recommendation: Validate incident-response readiness, monitor for exposed credentials, and reinforce MFA, phishing resistance, and data-loss controls.

Sources: <https://www.bleepingcomputer.com/news/security/maine-disables-data-breach-notification-portal-after-fake-disclosures/>

09. [+48h Old] Google Sues Chinese Smishing Network Accused of Using Gemini AI in Phishing

Google on Friday said it's pursuing legal action against a Chinese cybercrime network, accusing it of using its Gemini artificial intelligence (AI) agent to send phishing text messages targeting Americans. The network is said to be behind the development and management of a phishing-as-a-service (PhaaS) software kit called Outsider, per the tech giant. "The...

Why it matters: Breaches and cybercrime activity signal where attackers are focusing and what data types are actively monetized.

Recommendation: Validate incident-response readiness, monitor for exposed credentials, and reinforce MFA, phishing resistance, and data-loss controls.

Sources: <https://thehackernews.com/2026/06/google-sues-chinese-smishing-network.html>

10. [+48h Old] Ukrainian national pleads guilty to role in Conti ransomware operation

A Ukrainian national extradited from Ireland to the United States last year has pleaded guilty to conspiracy charges tied to the Conti ransomware operation. [...]

Why it matters: Ransomware operations combine disruption with extortion, making recovery speed and data-resilience core business risks.

Recommendation: Verify offline backups, test restores, harden remote access, and review segmentation to limit lateral movement.

Sources: <https://www.bleepingcomputer.com/news/security/ukrainian-national-pleads-guilty-to-role-in-conti-ransomware-operation/>